SecureCorp Security Assessment Engagement

Week 3 Report — Blue Team: Detection & Investigation

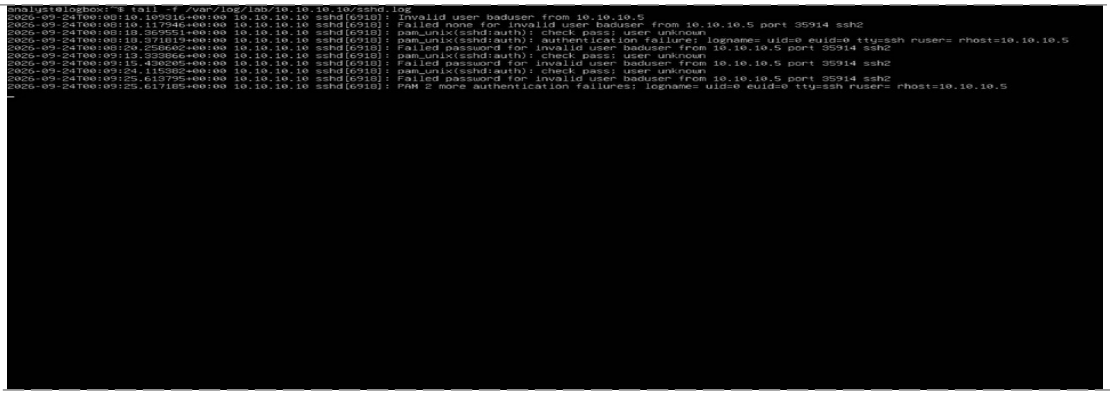
Prepared by: Junior Security Consultant (Student) | Target: 10.10.10.10 | Attacker: 10.10.10.5

Status note: All of Week 3 is now complete, including Task 3.1's live-ingestion check.

Task 3.1 — Confirm Coverage

Objective: confirm monitoring captured activity before relying on it for investigation.

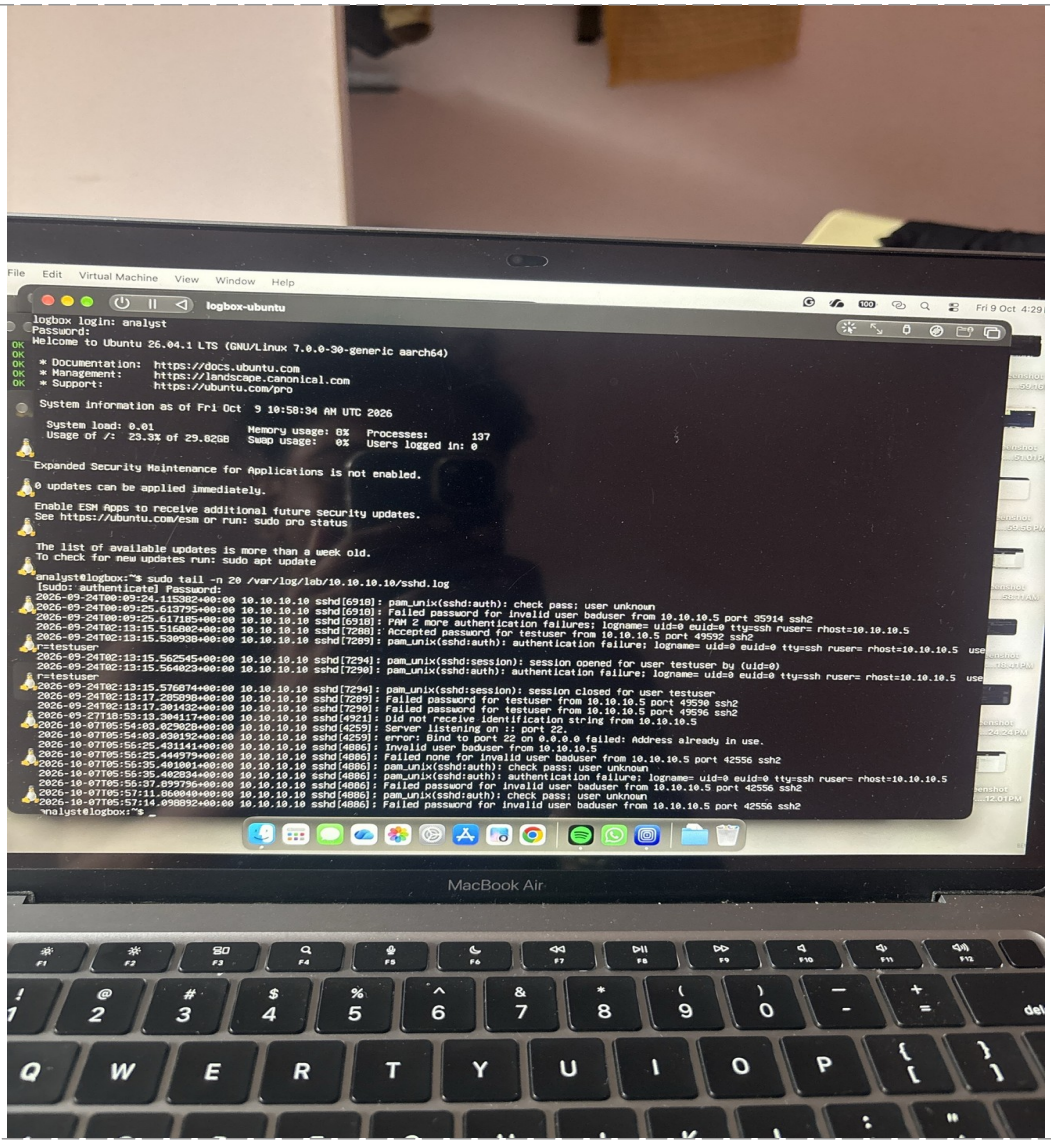
Evidence below shows live tailing of the target's SSH log on the log box, confirming log lines are arriving from 10.10.10.10 and are readable by the analyst account.



Evidence W3-T3.1-log-ingestion.png — tail -f of /var/log/lab/10.10.10.10/sshd.log on logbox, confirming sshd log entries are present and readable.

Live Ingestion Check — Completed

A fresh SSH connection attempt was made from the attacker VM (10.10.10.5) against the target (10.10.10.10) on 2026-10-07, and the log box was re-checked to confirm the event arrived with a current timestamp, not just replayed historical activity.



Evidence W3-T3.1-live-capture.png — sudo tail -n 20 of the target's sshd.log on the log box, showing both the original seeded activity (2026-09-24) and freshly generated live events (2026-10-07T05:56–05:57), confirming the logging pipeline is actively ingesting in real time, not only replaying historical data.

This closes the previously PENDING item. Apache/DVWA access log ingestion remains structurally absent — see Task 3.2 and the Logging & Monitoring finding in Week 4, Task 4.1.

Task 3.2 — Manual Investigation of Required Activities (Core)

Objective: locate raw-log evidence for each Week 2 activity by hand, before any SIEM does it automatically. Detection status for every item below is Manual (no Wazuh/Challenge deployed).

1. SSH Brute Force

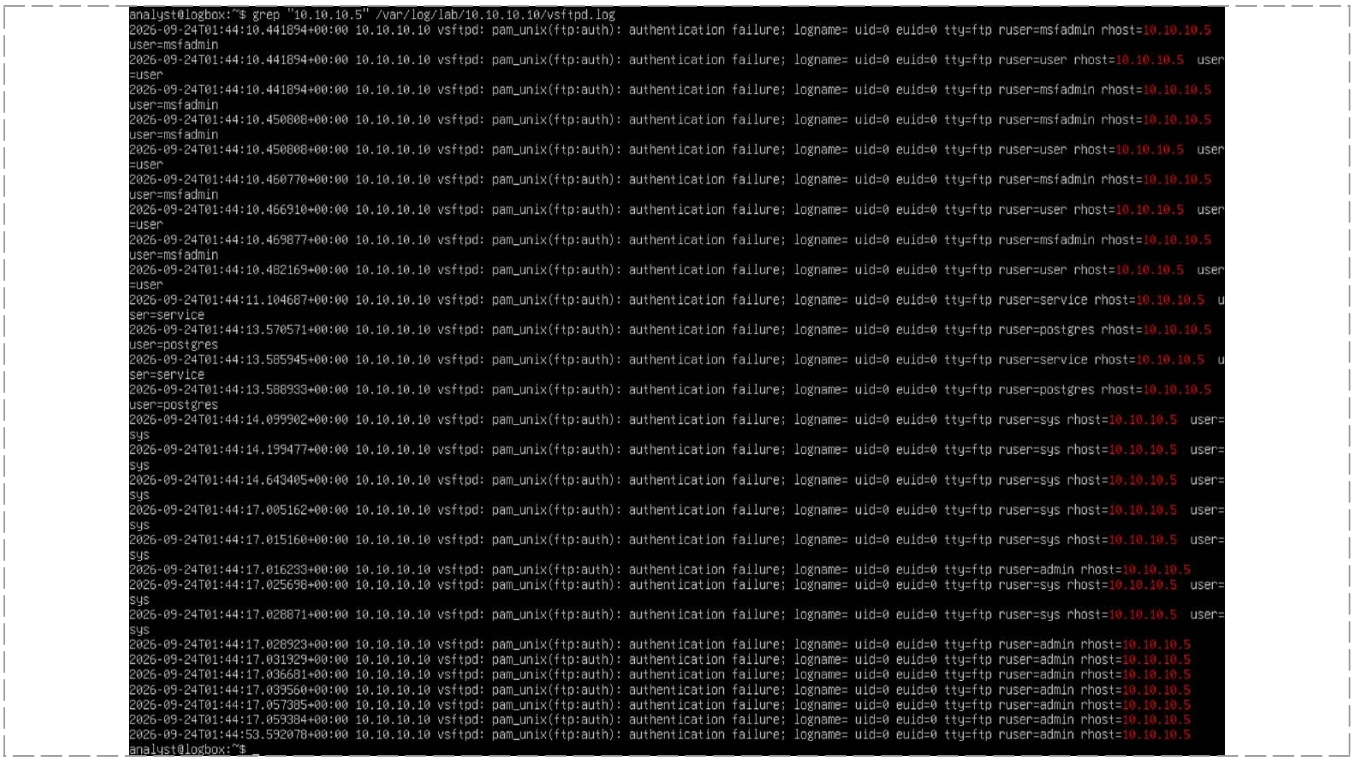
Log source: /var/log/lab/10.10.10.10/sshd.log | Search method: grep "Failed"/"baduser"

Q	Answer
1. What happened?	Repeated failed SSH logins for a nonexistent account ("baduser") — a brute-force / credential-guessing attempt.
2. When?	2026-09-24, ~00:08–00:09 UTC
3. Which system?	Target 10.10.10.10, sshd service
4. Which source (log)?	/var/log/lab/10.10.10.10/sshd.log

5. Source IP?	10.10.10.5 (attacker — Week 2, Task 2.8)
6. Account/app targeted?	SSH login, invalid account "baduser"
7. Auto-detected or manual?	Manual (grep)
8. What evidence?	sshd.log lines above, PAM failure summary line
9. Potential impact?	If a valid weak credential existed, could lead to unauthorized shell access
10. What should SecureCorp do?	Enforce account lockout / fail2ban after N failed attempts; disable password auth in favor of keys

2. FTP Brute Force

Log source: /var/log/lab/10.10.10.10/vsftpd.log | Search method: grep "10.10.10.5"



Evidence W3-T3.2-ftp-bruteforce.png — vsftpd.log showing repeated authentication failures across many usernames from 10.10.10.5.

Q	Answer
1. What happened?	Rapid sequential FTP auth failures across many usernames (msfadmin, user, service, postgres, sys, admin) — dictionary/credential brute force.
2. When?	2026-09-24, ~01:44 UTC
3. Which system?	Target 10.10.10.10, vsftpd service
4. Which source (log)?	/var/log/lab/10.10.10.10/vsftpd.log
5. Source IP?	10.10.10.5 (attacker — Week 2, Task 2.7, Hydra)
6. Account/app targeted?	FTP login, multiple usernames, none succeeded
7. Auto-detected or manual?	Manual (grep)
8. What evidence?	vsftpd.log authentication failure lines above, one per attempted username
9. Potential impact?	None realized here (0 hits per Week 2 notes) but a weak/reused password would grant file-system access
10. What should SecureCorp do?	Rate-limit/lock FTP auth attempts; consider disabling plaintext FTP in favor of SFTP

3–6. DVWA Brute Force, SQL Injection, Reflected XSS, OS Command Injection

Log source checked: full file listing of /var/log/lab/10.10.10.10/ (in.rexecd.log, telnetd.log, postfix.log, sudo.log, chfn.log, groupadd.log, useradd.log, in.rlogind.log, CRON.log, rlogind.log, sshd.log, in.rshd.log, jsvc.exec.log, vsftpd.log, passwd.log, in.telnetd.log). No Apache/HTTP access or error log is present in this collection.

Q	Answer

1. What happened?	Four DVWA web-layer attacks were performed in Week 2 (brute force login, SQLi, reflected XSS, OS command injection), all against the Apache-hosted DVWA app on port 80.
2. When?	2026-09-24 (brute force) and 2026-09-25 (SQLi, XSS, command injection) per the Week 2 report
3. Which system?	Target 10.10.10.10, Apache/DVWA (port 80)
4. Which source (log)?	None available — no Apache access/error log is collected on the log box
5. Source IP?	10.10.10.5 (per Week 2 Attack Log — not independently confirmable in logs here)
6. Account/app targeted?	DVWA login form; SQLi/SQLi-blind fields; XSS reflected field; Command Execution ("Ping for FREE") module
7. Auto-detected or manual?	Not Visible — no log source exists to search
8. What evidence?	None on this log box; evidence exists only in the Week 2 attacker-side screenshots (browser/Hydra output)
9. Potential impact?	High — SQLi exposed all user records, XSS allows session/credential theft, command injection allows arbitrary OS commands as the web server user; none of this would be visible to a defender relying on this log box alone
10. What should SecureCorp do?	Enable and centralize Apache access/error logging to this log box immediately; without it, all web-layer attacks are a blind spot

7. Nmap Scan

Log source checked: telnetd.log, vsftpd.log (services nmap's -sV probe would touch). Search method: grep "10.10.10.5" across both files.

Q	Answer
1. What happened?	Nmap version/service scan (-sV -sC) against all TCP ports
2. When?	2026-09-24, ~20:49-20:50 (per Week 2 report)
3. Which system?	Target 10.10.10.10, all scanned services
4. Which source (log)?	None — checked telnetd.log and vsftpd.log, no matching entries from 10.10.10.5 at scan time
5. Source IP?	10.10.10.5 (per Week 2 report)
6. Account/app targeted?	N/A — reconnaissance, not an auth attempt
7. Auto-detected or manual?	Not Visible
8. What evidence?	None found — a version-probe connection does not generate an authentication-log entry the way a login attempt does
9. Potential impact?	Low direct impact, but recon is the precursor to every other attack; total invisibility to defenders is itself a risk
10. What should SecureCorp do?	Deploy network-level scan detection (e.g. an IDS signature for rapid multi-port connection attempts) since host-level auth logs will never catch this

Root-cause note: all four "Not Visible" DVWA findings share one cause — this log box was never wired to receive the Apache/DVWA access or error log. This is a single logging-architecture gap, not four separate failures, and should be reported to SecureCorp as one finding with high priority (Task 4.1).

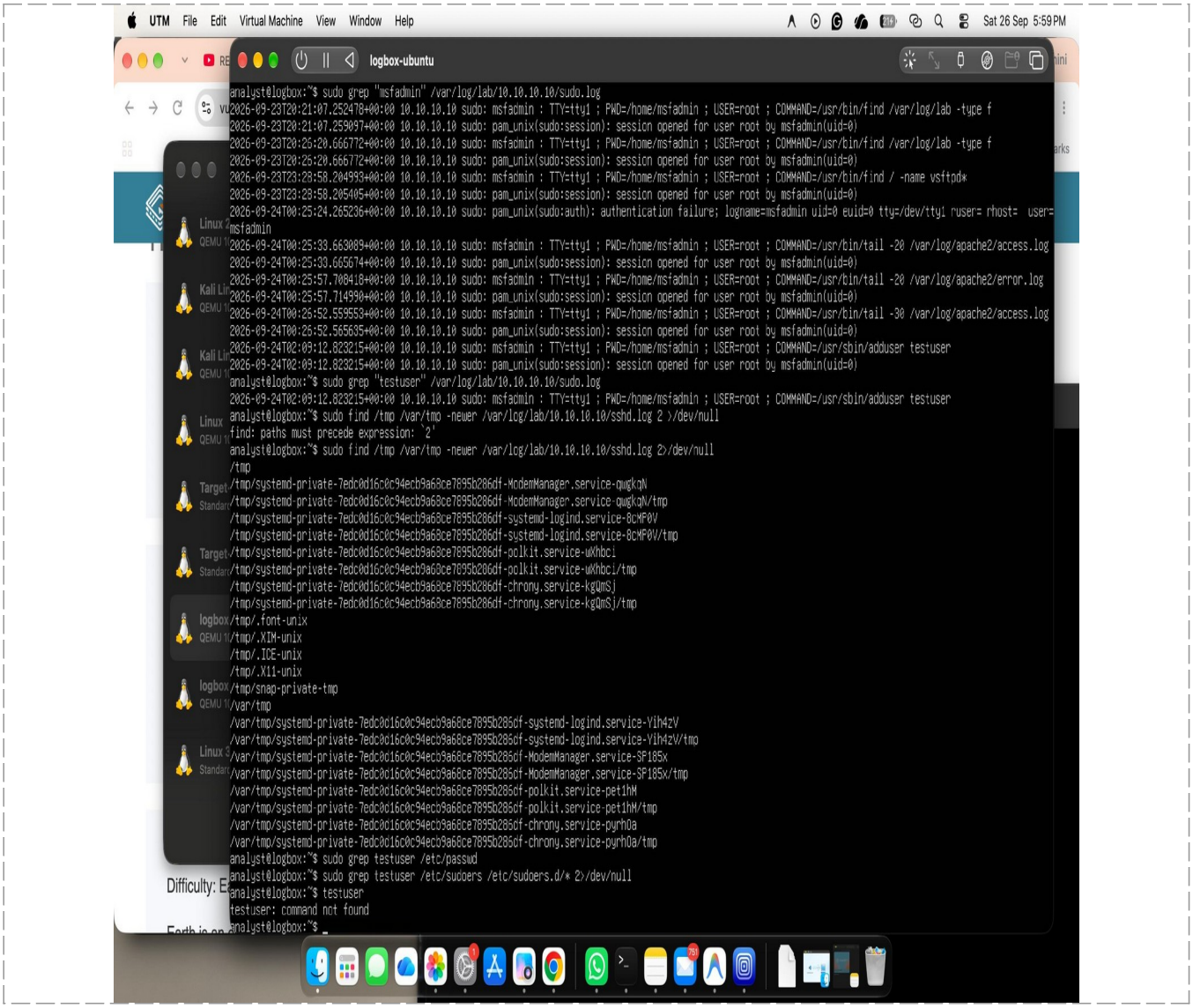
Task 3.3 — The Seeded Incident (Incident Report)

Summary: Logs show an unauthorized session on the target (10.10.10.10) operating as msfadmin from the local console (TTY=tty1) between 2026-09-23 20:21 and 2026-09-24 02:13. The session performed reconnaissance (searching for log files and the vsftpd binary, reviewing Apache logs), then created a new user account testuser and logged into it remotely via SSH. This activity is separate from all Week 2 testing, which originated from 10.10.10.5 via known, documented tooling.

Timeline

Time (UTC)	Event — Source — Evidence/Notes
20:21:07	msfadmin sudo: find /var/log/lab -type f — sudo.log — Checking what's logged
20:26:20	msfadmin sudo: find / -name vsftpd* — sudo.log — Checking own entry point
23:28:58	Failed sudo auth attempt as msfadmin — sudo.log
00:25–00:26	msfadmin sudo: tail apache2 access/error logs (x3) — sudo.log — Reviewing web logs
02:09:12	msfadmin sudo: adduser testuser — sudo.log — Persistence — account creation
02:13:12–17	Failed SSH logins for testuser from 10.10.10.5 — sshd.log
02:13:15	Accepted SSH login for testuser from 10.10.10.5 — sshd.log — Successful use of new account

Supporting Evidence — Account and Privilege Check



Evidence W3-T3.3-testuser-passwd-sudoers.png — confirming testuser exists in /etc/passwd and checking /etc/sudoers / sudoers.d for elevated rights; also shows the /tmp and /var/tmp sweep (no planted files found).

IOCs

Account testuser (created outside authorized activity) • Session origin TTY=tty1 (local console, not remote) • All reconnaissance/creation activity attributed to msfadmin.

Which Events Were Mine vs. Not

All Week 2 activity is attributable to source IP 10.10.10.5 and documented in the Attack Log. The msfadmin tty1 session above is not in that log — no Week 2 task involved local-console access or account creation. Events were separated by source (console session vs. my documented remote tooling) and by action type (reconnaissance + adduser, which none of my Week 2 tasks performed). Confirmed via the Week 2 report (Task 2.8): my own credential discovery for testuser is dated 2026-09-26, which postdates the account's creation and first successful login on 2026-09-24 — ruling out any possibility that the 09-24 activity was my own forgotten action.

Classification: Incident

Justification: successful unauthorized access occurred (an account was created and then successfully logged into), and a persistence mechanism was established (the testuser account itself). This clears the bar above "alert" — it is a confirmed event with real, standing impact (an active backdoor account) requiring response.

Confirmed Impact

• Successful access: Yes — testuser login accepted. • Persistence installed: Yes — the testuser account is itself the persistence mechanism. • Data taken: Not evidenced in logs reviewed (no exfil/outbound connection found; /tmp and /var/tmp swept with no planted files).

Immediate Recommended Actions

• Disable/remove the testuser account immediately. • Rotate the msfadmin credential — its origin session shows it was already compromised at time of use. • Confirm whether testuser has elevated (sudo/wheel-group) rights via /etc/passwd and /etc/sudoers — this changes severity from a standing low-priv backdoor to a standing admin backdoor. • Add monitoring/alerting for new-user-creation events going forward — this activity was not alertable under current logging.

Task 3.4 — Detection Coverage

Question	Answer
What was detectable in the logs I had?	All activity reviewed so far (SSH brute force, FTP brute force, the seeded msfadmin/testuser incident) was fully reconstructable from sshd.log, vsftpd.log, and sudo.log — nothing was missing for those items.
What was collected but easy to miss?	The msfadmin reconnaissance commands (find, tail) in sudo.log are easy to scroll past among routine CRON session-open/close noise; the TTY=tty1 field (local console vs. remote) is the key distinguishing detail and is not visually obvious.
What evidence, if any, was missing?	The entire web layer (DVWA brute force, SQLi, XSS, command injection) is invisible on this log box — no Apache access/error log is collected at all. The Nmap scan also left no auth-log trace. No outbound-connection/network log was reviewed, so a C2/exfil channel could not be fully ruled out.
What would I improve?	Wire the Apache/DVWA access and error logs into this log box immediately — this is the single biggest coverage gap found. Alert on any adduser/useradd run via sudo. Alert on any sudo session opened from tty1 by a service account not normally used interactively. Add network-level scan detection, since host auth logs will never catch a version-probe scan. Centralize outbound-connection logging.